

Web 安全作业 2：Web 漏洞利用

Copyright © 2020 - 2025 Jian Mao, Beihang University
Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at <http://www.gnu.org/licenses/fdl.html>

一、作业内容

1.1 作业环境介绍与配置

课程作业的虚拟环境在 VirtualBox 上运行。在 VirtualBox 上，导入作业二虚拟环境 a2.vdi。该虚拟环境有一台虚拟机，运行 Ubuntu 14.04 系统，账户名为 student，口令为 student。在该实验中，虚拟机 a2 同时作为 Web 站点服务器与数据库服务器，并部署包含不同 Web 漏洞的网页应用，它们的主页为 <http://www.wsb.com/Assignment2>，源码位于 `/var/www/html/Assignment2/` 目录下。本作业需要从不同的网页应用中发现并利用相应的 Web 漏洞。

1.2 具体内容

表 1 列出了 10 个网页应用对应的 Web 漏洞类别与漏洞利用目标。其中，flag 是嵌入在该网页应用中的秘密字段，请利用漏洞找到并输出它。

表 1 网页应用的漏洞类别与利用目标

网页应用编号	漏洞分类	目标
04	存储型 XSS	获取 Cookie 中的 flag
06	混合内容	获取 Cookie 中的 flag
07	反射型 XSS	获取 Cookie 中的 flag
09	CSRF	构建一个包含简单表单的脚本，用于向 case09.php 发送信息
14	参数污染	获取被污染页面中的 flag
23	认证缺陷	提升权限后获取 flag
24	SQL 注入	获取数据库中的 Flag
25	本地文件包含	获取 Assignment2 目录下 fi.txt.php 文件中包含的 flag
31	远程代码执行	执行 <code>cat /etc/passwd</code>
32	重定向后执行	获取服务器输出的 flag

1.3 评分细则

本次作业共 20 分，每个漏洞 2 分。对于每一个漏洞，都需要完成：

- 识别漏洞并描述（0.5 分）；
- 解释并展示如何利用发现的漏洞（1 分）；
- 除网页应用 06 外，需要使用自动化的攻击脚本（**bash 脚本文件**）完成漏洞利用过程，并展示结果；对于网页应用 06，只需要展示利用过程与结果截图即可（0.5 分）。

攻击脚本的示例位于 `/var/www/html/Assignment2/sample` 目录中，请参考它构建对其他网页应用的攻击脚本。此外，可以在脚本中使用第三方库，如果在当前作业环境中没有安装所需的第三方库，可以自行构建环境配置脚本（`setup.sh`）进行安装。

对于上述漏洞，助教将执行环境配置脚本（`setup.sh`）与对应的漏洞利用脚本（如，`exploit04.sh`、`exploit09.sh` 等），检查其是否实现对应的利用目标。请注意，助教只会执行 **bash 脚本文件**，因此，可以使用其他编程语言编写漏洞利用代码，但仍需要编写脚本文件调用对应代码文件。

二、作业提交要求

1. 完成所有作业内容，按要求截图记录作业过程与结果，并回答相应问题；
2. 报告条理清晰，重点突出，排版工整；
3. 报告命名为“hw2-report-学号.pdf”，并**转成 PDF 格式**；
4. 作业要求提交的代码文件统一放入名为“hw2-code-学号”的文件夹；
5. 将报告文档（PDF 格式）与代码文件夹一起以 **ZIP 格式** 压缩，命名为“hw2-学号.zip”，压缩包通过 spoc 平台作业功能提交。